**DEPARTMENT OF COMPUTER SCIENCE**

## Course Title: Ethical Hacking

## Objective

The objective of this experiment is to perform domain and DNS reconnaissance using WHOIS, nslookup, and theHarvester. These tools help collect domain registration details, resolve DNS records, enumerate email addresses and subdomains, and understand how DNS spoofing can be used to redirect traffic within a controlled lab environment.

## Methodology

1. Perform WHOIS queries to retrieve domain registration details, registrar information, nameservers, and registration dates.
2. Use nslookup to query DNS servers and resolve domain names into IP addresses, mail servers, and name server records.
3. Use theHarvester to gather publicly available information such as email addresses and subdomains related to the target domain.
4. Set up a mock site within the isolated lab network and simulate DNS spoofing to understand how DNS traffic can be manipulated.
5. Analyze the information collected from all tools to build a complete picture of the target's domain and DNS environment.

## Expected Outcome

By completing this experiment, you will be able to:

1) Retrieve domain registration and ownership details using WHOIS.
2) Resolve and interpret DNS records using nslookup.
3) Collect publicly available emails and subdomains using theHarvester.
4) Understand how DNS resolution works and how it can be spoofed.
5) Gain practical experience with domain-level reconnaissance techniques used in the early stages of an ethical hacking assessment.

# INDEX


| S.No | Topic | Page No. |
|---|---|---|
| 1 | Introduction to DNS | 3 |
| 2 | Introduction to WHOIS | 3 |
| 3 | Setting up WHOIS | 3 |
| 4 | WHOIS Commands | 4 |
| 5 | Introduction to nslookup | 6 |
| 6 | Setting up nslookup | 6 |
| 7 | nslookup Commands | 7 |
| 8 | Introduction to theHarvester | 9 |
| 9 | Setting up theHarvester | 9 |
| 10 | theHarvester Commands for Email Enumeration | 11 |
| 11 | DNS Mapping | 13 |
| 12 | Introduction to Nikto | 15 |
| 13 | Installing Nikto | 15 |
| 14 | Nikto Command Syntax | 16 |
| 15 | Running a Basic Scan | 16 |
| 16 | Common Scan Options | 17 |

## 1.Introduction to DNS

DNS (Domain Name System) is the system that translates human-readable domain names, such as example.com, into machine-readable IP addresses. It acts as the "phonebook" of the internet, allowing browsers and applications to locate servers without users needing to remember numeric addresses.

### 1.1. Uses of DNS

- Resolves domain names to IP addresses.
- Stores mail server records (MX) for email routing.
- Stores name server (NS) records identifying authoritative DNS servers.
- Enables load balancing and failover through multiple DNS records.

## 2. Introduction to WHOIS

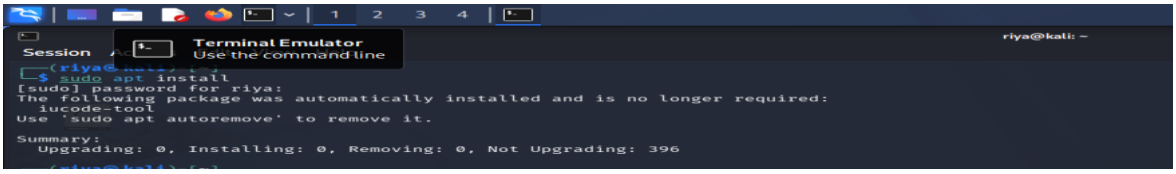
WHOIS is a command-line tool used to retrieve registration information about a domain name or IP address. It provides details such as the registrar, registration dates, nameservers, and registration status.

## 3. Setting up WHOIS

**Step 1: Update the Package List**

sudo apt update

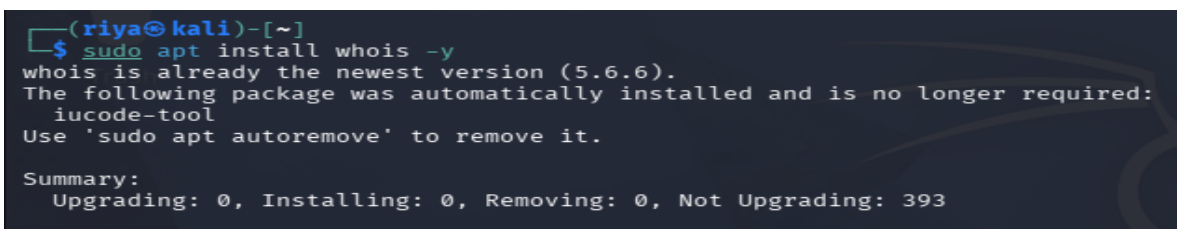
Updates the package repository information.




**Step 2: Install WHOIS**

sudo apt install whois

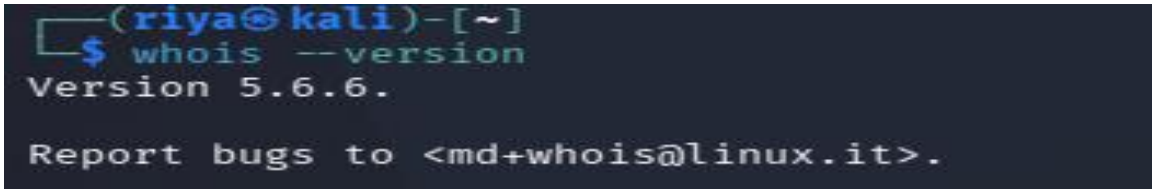
Installs the WHOIS command-line tool.



### Step 3: Verify Installation

whois --version

Displays the installed version of the WHOIS tool (if supported).




## 4. WHOIS Commands

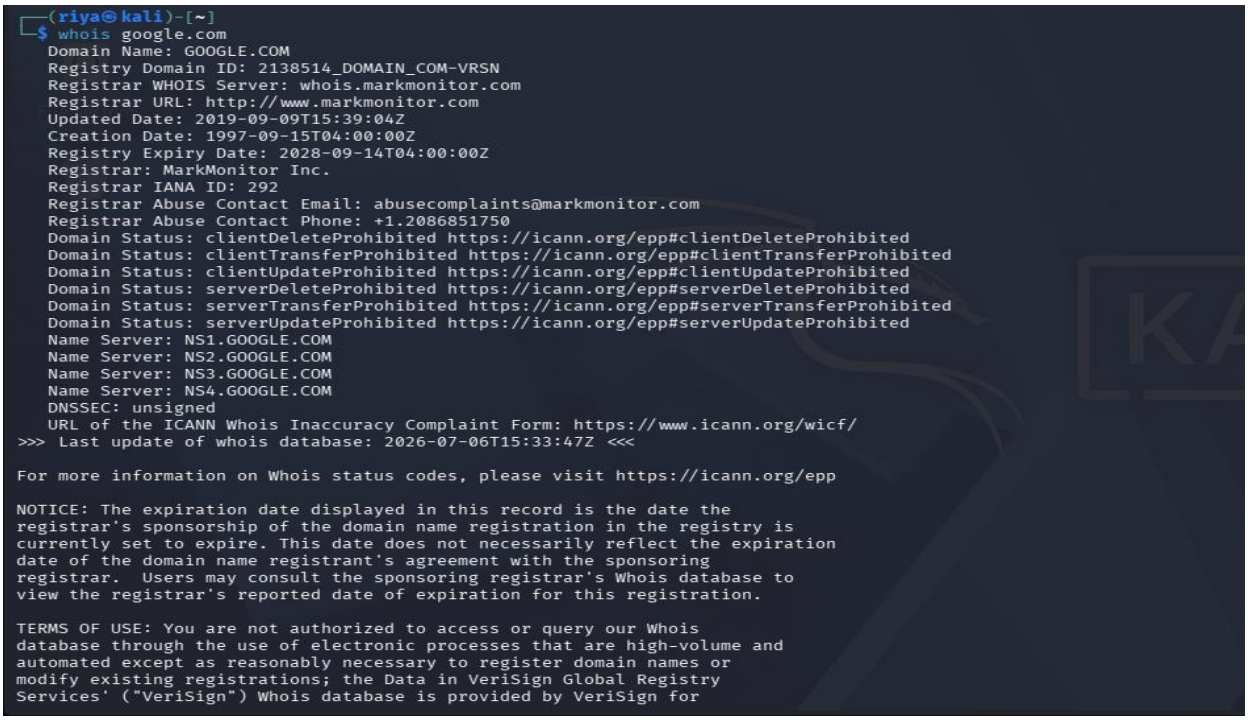
### 4.1. Basic Syntax

whois <domain_or_ip>

### 4.2. Look Up a Domain

whois example.com

Retrieves registration details for the domain example.com.



### 4.3. Look Up an IP Address

whois 8.8.8.8

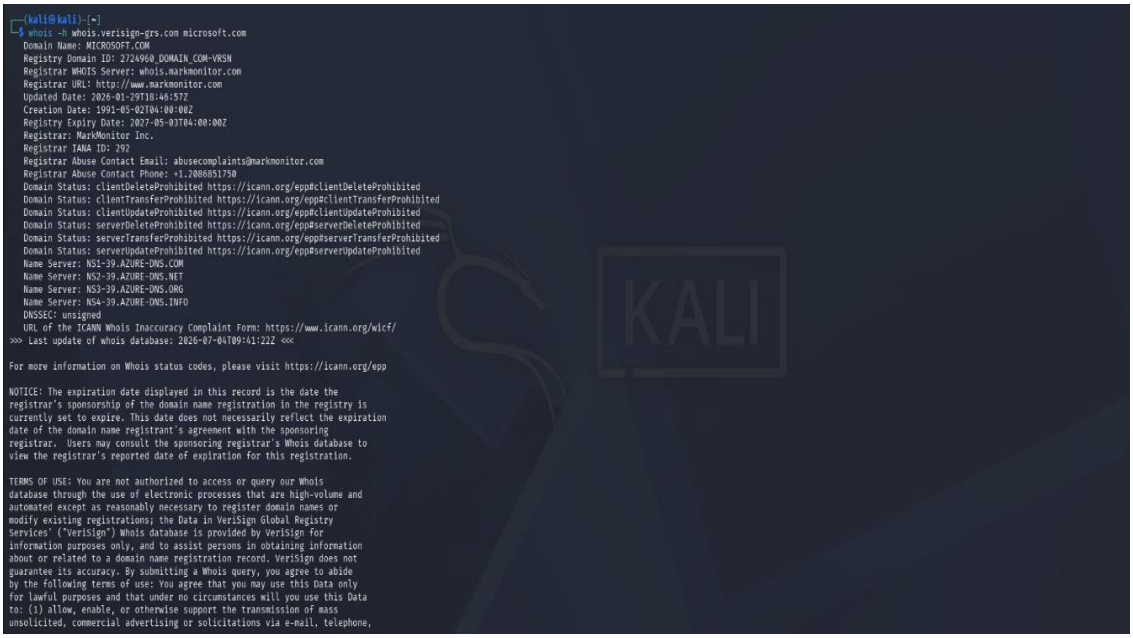
Displays registration information for the specified IP address.




### 4.4. Query a Specific WHOIS Server

whois -h whois.verisign-grs.com example.com

- -h → Specifies the WHOIS server to query.
- Useful when you want to query a particular registry directly.



## 5. Introduction to nslookup

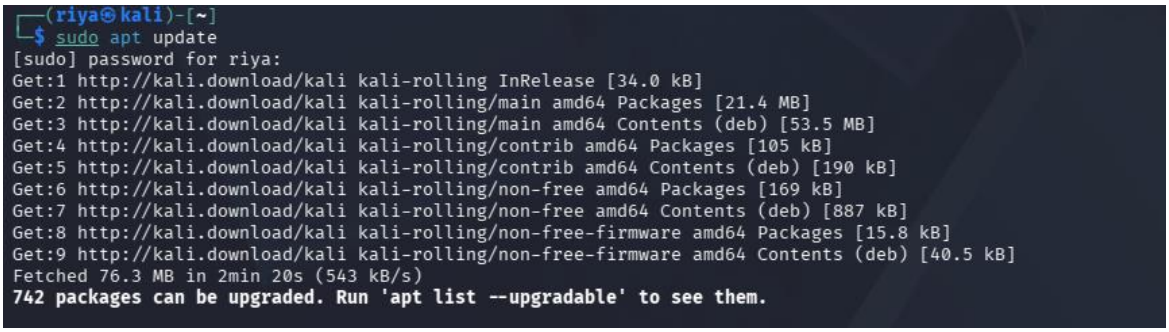
nslookup (name server lookup) is a command-line tool used to query DNS servers and resolve domain names, mail servers, and name server records. It is one of the most commonly used tools for basic DNS troubleshooting and reconnaissance.

## 6. Setting up nslookup

### Step 1: Update the Package List

sudo apt update

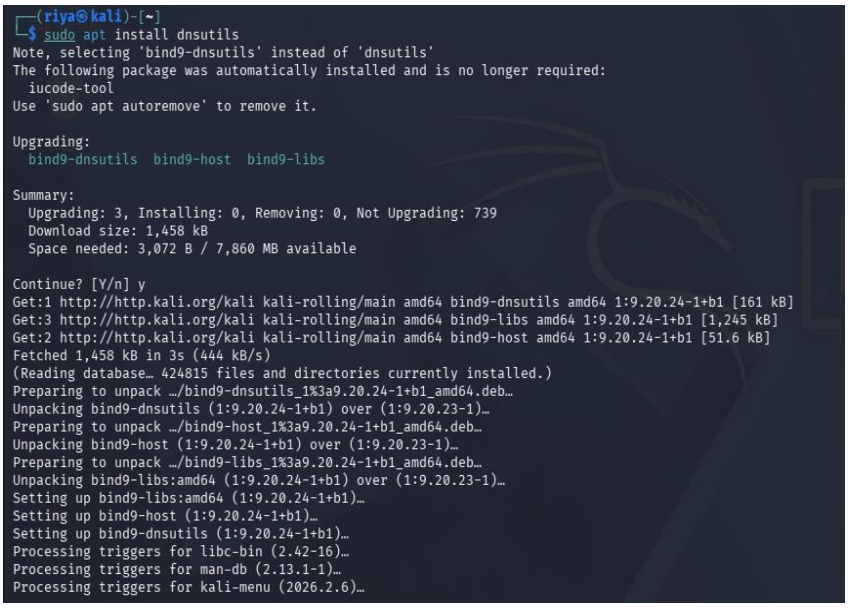
Updates the package repository information.




### Step 2: Install dnsutils (provides nslookup)

sudo apt install dnsutils

Installs nslookup along with other DNS utility tools.



### Step 3: Verify Installation

nslookup

Launches the interactive nslookup prompt, confirming installation.

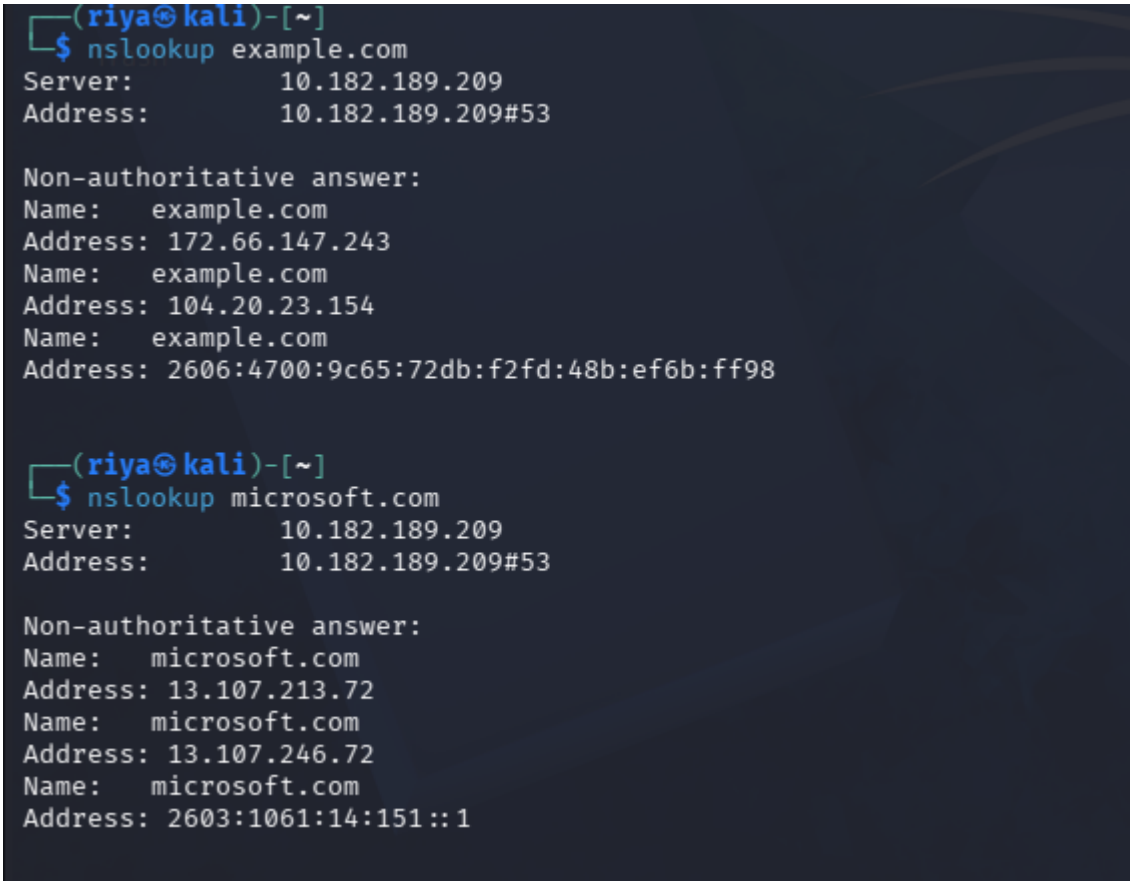



## 7. nslookup Commands

### 7.1. Basic Domain Lookup

nslookup example.com

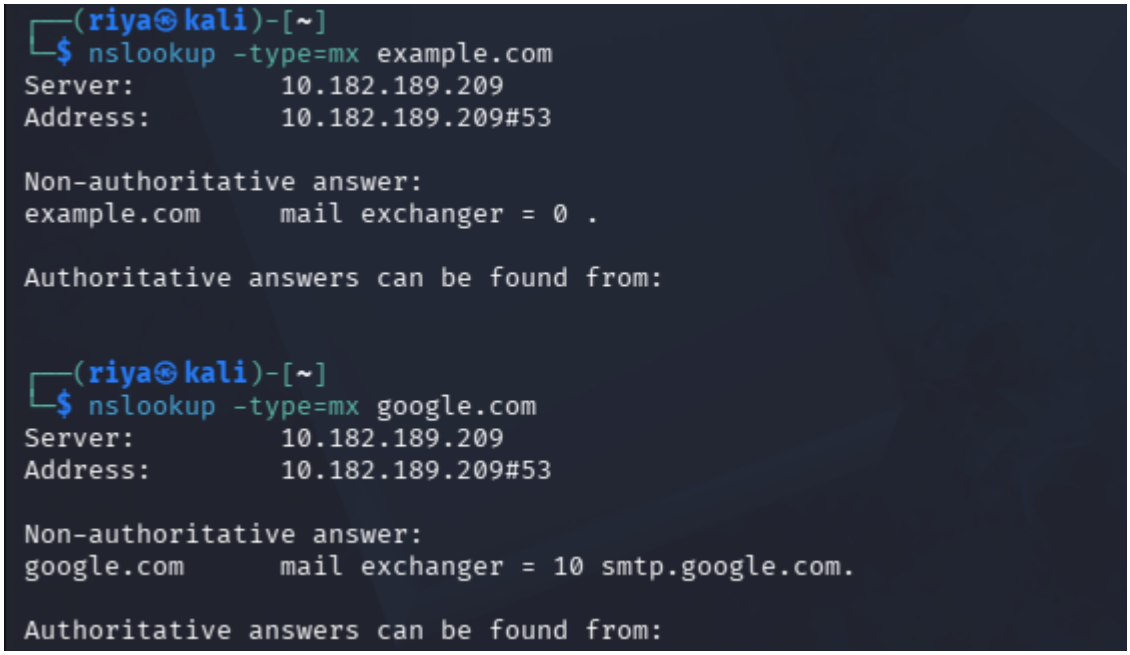
Resolves the domain to its IP address(es).




### 7.2. Query Mail Server (MX) Records

nslookup -type=mx example.com

Displays the mail servers responsible for handling email for the domain.




### 7.3. Query Name Server (NS) Records

nslookup -type=ns example.com

Displays the authoritative name servers for the domain.

```
┌──(riya㉿kali)-[~]
└─$ nslookup -type=ns example.com
Server:         10.182.189.209
Address:        10.182.189.209#53

Non-authoritative answer:
example.com     nameserver = hera.ns.cloudflare.com.
example.com     nameserver = elliott.ns.cloudflare.com.

Authoritative answers can be found from:


┌──(riya㉿kali)-[~]
└─$ nslookup -type=ns microsoft.com
Server:         10.182.189.209
Address:        10.182.189.209#53

Non-authoritative answer:
microsoft.com   nameserver = ns4-39.azure-dns.info.
microsoft.com   nameserver = ns1-39.azure-dns.com.
microsoft.com   nameserver = ns2-39.azure-dns.net.
microsoft.com   nameserver = ns3-39.azure-dns.org.

Authoritative answers can be found from:
```

### 7.4. Query a Specific DNS Server

nslookup example.com 8.8.8.8

Queries the domain using Google's public DNS server (8.8.8.8) instead of the default.

```
┌──(riya㉿kali)-[~]
└─$ nslookup example.com 8.8.8.8
Server:         8.8.8.8
Address:        8.8.8.8#53

Non-authoritative answer:
Name:   example.com
Address: 104.20.23.154
Name:   example.com
Address: 172.66.147.243
Name:   example.com
Address: 2606:4700:8ca5:72db:f242:0:ef6b:ff98
```

### 7.5. Reverse DNS Lookup

nslookup 8.8.8.8

Resolves an IP address back to its associated domain name, where available.

```
┌──(riya㉿kali)-[~]
└─$ nslookup 8.8.8.8
8.8.8.8.in-addr.arpa    name = dns.google.

Authoritative answers can be found from:
```

## 8. Introduction to theHarvester

theHarvester is an Open Source Intelligence (OSINT) tool used to collect publicly available information such as email addresses, subdomains, hostnames, and IP addresses about a target domain. It is commonly used during the reconnaissance phase of cybersecurity assessments.

## 9. Setting up theHarvester

### Step 1: Update the System

sudo apt update

Updates the package list from the repositories.

```
┌──(riya㉿kali)-[~]
└─$ sudo apt update
[sudo] password for riya:
Get:1 http://kali.download/kali kali-rolling InRelease [34.0 kB]
Get:2 http://kali.download/kali kali-rolling/main amd64 Packages [21.4 MB]
Get:3 http://kali.download/kali kali-rolling/main amd64 Contents (deb) [53.5 MB]
Get:4 http://kali.download/kali kali-rolling/contrib amd64 Packages [105 kB]
Get:5 http://kali.download/kali kali-rolling/contrib amd64 Contents (deb) [190 kB]
Get:6 http://kali.download/kali kali-rolling/non-free amd64 Packages [169 kB]
Get:7 http://kali.download/kali kali-rolling/non-free amd64 Contents (deb) [887 kB]
Get:8 http://kali.download/kali kali-rolling/non-free-firmware amd64 Packages [15.8 kB]
Get:9 http://kali.download/kali kali-rolling/non-free-firmware amd64 Contents (deb) [40.5 kB]
Fetched 76.3 MB in 2min 20s (543 kB/s)
742 packages can be upgraded. Run 'apt list --upgradable' to see them.
```

### Step 2: Install theHarvester

sudo apt install theharvester

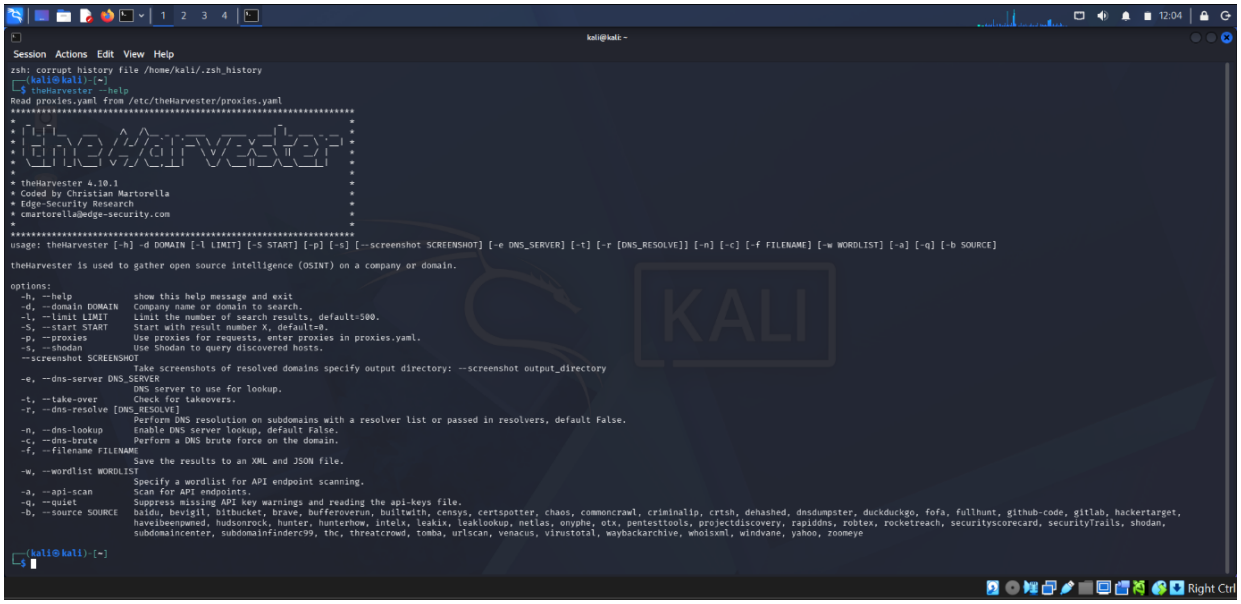
Installs theHarvester from the distribution's package repository.




### Step 3: Verify Installation

theHarvester --version

Displays the installed version of theHarvester.




## 10. theHarvester Commands for Email Enumeration

### 10.1. Basic Syntax

theHarvester -d <domain> -b <source>

- -d → Target domain
- -b → Data source to search

### 10.2. Enumerate Emails from a Domain

theHarvester -d example.com -b google

Searches Google for publicly listed email addresses associated with the domain.

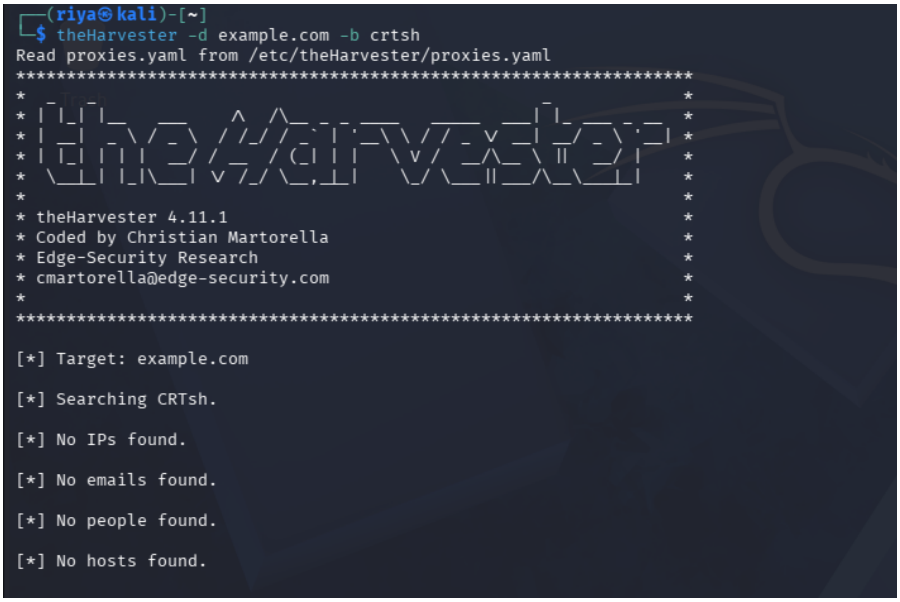
theHarvester -d microsoft.com -b google




### 10.3. Enumerate Using Certificate Transparency Logs

theHarvester -d example.com -b crtsh

Searches certificate transparency logs for subdomains and related hosts.




### 10.4. Limit the Number of Results

theHarvester -d example.com -b crtsh,hackertarget -l 20

-l → Limits the number of results returned.

```
┌──(riya㉿kali)-[~]
└─$ theHarvester -d example.com -b crtsh,hackertarget -l 20
Read proxies.yaml from /etc/theHarvester/proxies.yaml
*******************************************************************
*  _   _                                            _             *
* | |_| |__    ___      ^  /\__ _ _ ____   _____ ___| |_ ___ _ __  *
* | __|  _ \ / _ \  / /_/ / _` | '__\ \ / / _ v _ \ __| __/ _ \ '__| *
* | |_| | | |  __/ / __  / (_| | |   \ v /  __/\__ \ ||  __/ |    *
*  \__|_| |_|\___| v /_/ \__,_|_|    \_/ \___||___/\__\___|_|      *
*                                                                 *
* theHarvester 4.11.1                                             *
* Coded by Christian Martorella                                   *
* Edge-Security Research                                          *
* cmartorella@edge-security.com                                   *
*                                                                 *
*******************************************************************

[*] Target: example.com

Read api-keys.yaml from /etc/theHarvester/api-keys.yaml
[*] Searching Hackertarget.
[*] Searching CRTsh.

[*] No IPs found.

[*] No emails found.

[*] No people found.

[*] Hosts found: 500
---------------------
0001.example.com:103.102.230.52
1.example.com:83.14.191.103
11.example.com:5.188.224.213
110711.example.com:195.123.208.128
120113.example.com:195.123.233.70
1207.example.com:185.224.212.55
1270011721.example.com:212.80.217.188
12758xz-vpn.example.com:185.147.81.188
133175.example.com:185.14.30.2
134330.example.com:195.123.212.105
139520.example.com:82.118.22.95
```

## 11. DNS Mapping

DNS mapping combines the outputs of WHOIS, nslookup, and theHarvester to build a complete picture of a domain's infrastructure — its registrar, name servers, mail servers, subdomains, and publicly listed emails.

### Step 1: Collect Registration Data

Run whois example.com and record the registrar and name servers.

```
┌──(riya㉿kali)-[~]
└─$ whois example.com
   Domain Name: EXAMPLE.COM
   Registry Domain ID: 2336799_DOMAIN_COM-VRSN
   Registrar WHOIS Server: whois.iana.org
   Registrar URL: http://res-dom.iana.org
   Updated Date: 2026-01-16T18:26:50Z
   Creation Date: 1995-08-14T04:00:00Z
   Registry Expiry Date: 2026-08-13T04:00:00Z
   Registrar: RESERVED-Internet Assigned Numbers Authority
   Registrar IANA ID: 376
   Registrar Abuse Contact Email:
   Registrar Abuse Contact Phone:
   Domain Status: clientDeleteProhibited https://icann.org/epp#clientDeleteProhibited
   Domain Status: clientTransferProhibited https://icann.org/epp#clientTransferProhibited
   Domain Status: clientUpdateProhibited https://icann.org/epp#clientUpdateProhibited
   Name Server: ELLIOTT.NS.CLOUDFLARE.COM
   Name Server: HERA.NS.CLOUDFLARE.COM
   DNSSEC: signedDelegation
   DNSSEC DS Data: 2371 13 2 C988EC423E3880EB8DD8A46FE06CA230EE23F35B578D64E78B29C3E1C83D245A
   URL of the ICANN Whois Inaccuracy Complaint Form: https://www.icann.org/wicf/
>>> Last update of whois database: 2026-07-21T11:13:52Z <<<

For more information on Whois status codes, please visit https://icann.org/epp

NOTICE: The expiration date displayed in this record is the date the
registrar's sponsorship of the domain name registration in the registry is
currently set to expire. This date does not necessarily reflect the expiration
date of the domain name registrant's agreement with the sponsoring
registrar.  Users may consult the sponsoring registrar's Whois database to
view the registrar's reported date of expiration for this registration.

TERMS OF USE: You are not authorized to access or query our Whois
database through the use of electronic processes that are high-volume and
automated except as reasonably necessary to register domain names or
modify existing registrations; the Data in VeriSign Global Registry
Services' ("VeriSign") Whois database is provided by VeriSign for
information purposes only, and to assist persons in obtaining information
about or related to a domain name registration record. VeriSign does not
guarantee its accuracy. By submitting a Whois query, you agree to abide
by the following terms of use: You agree that you may use this Data only
```

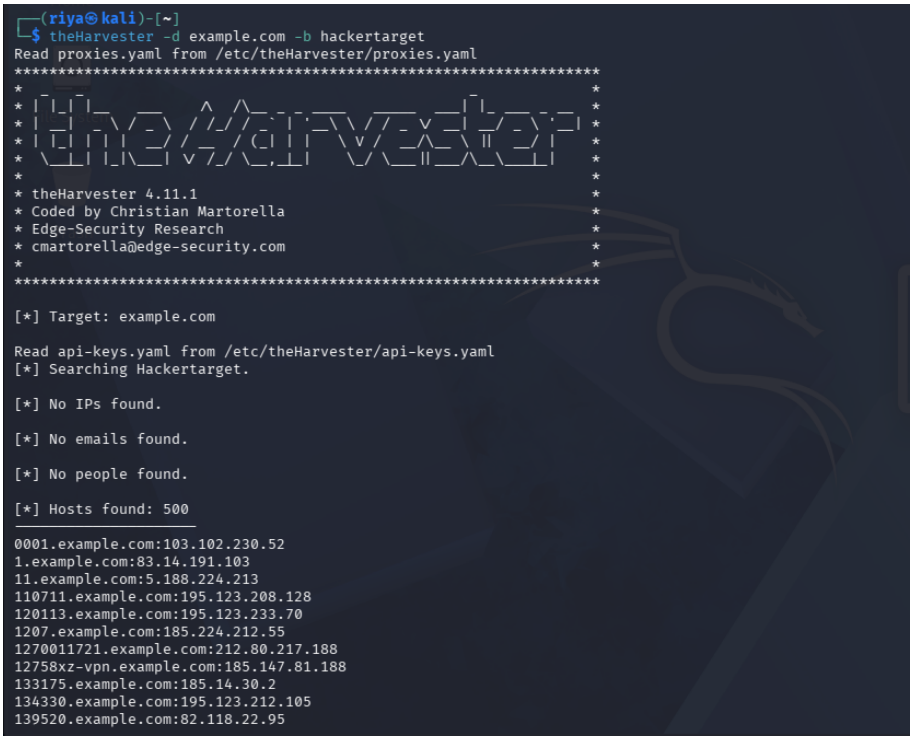
**Step 2: Collect DNS Records**

Run nslookup -type=mx and nslookup -type=ns to record mail and name server details.

```
┌──(riya㉿kali)-[~]
└─$ nslookup -type=mx and nslookup -type=ns
Usage:
   nslookup [-opt ...]             # interactive mode using default server
   nslookup [-opt ...] - server    # interactive mode using 'server'
   nslookup [-opt ...] host        # just look up 'host' using default server
   nslookup [-opt ...] host server # just look up 'host' using 'server'
```

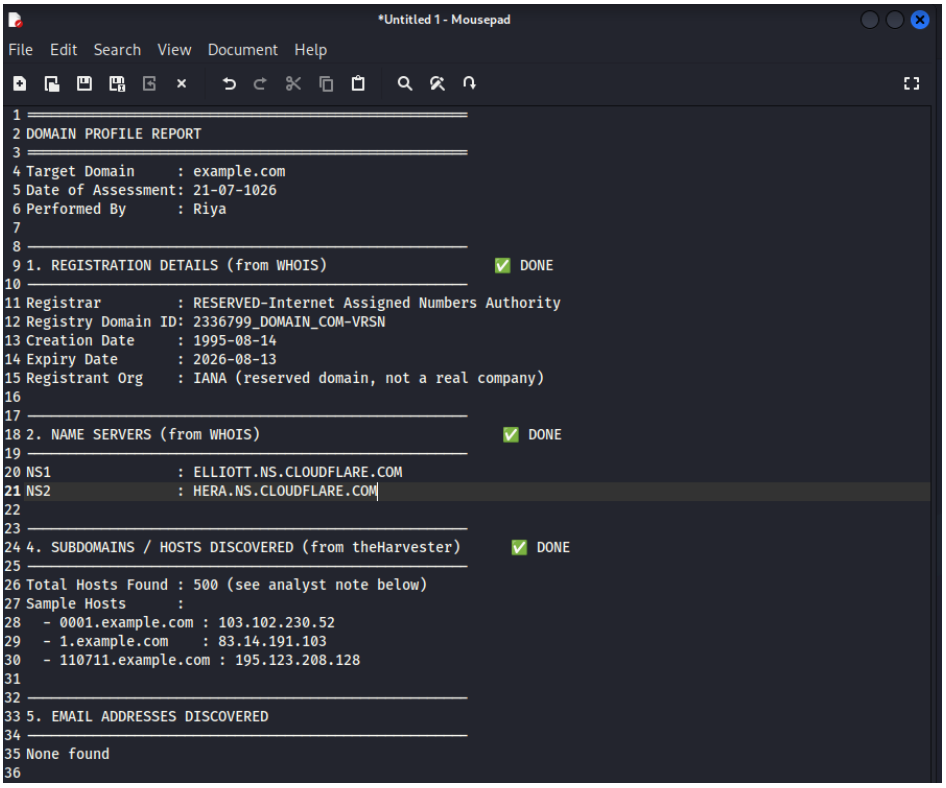
**Step 3: Collect Subdomains and Emails**

Run theHarvester -d example.com –b hackertarget all to gather subdomains and emails in one combined search.




**Step 4: Compile the Map**

Consolidate all findings (registrar, name servers, mail servers, subdomains, emails) into a single domain profile document.




# Nikto — Web Server Vulnerability Scanner

## 12. Introduction to Nikto

Nikto is a free, open-source command-line tool that scans a web server for thousands of known issues, including outdated software versions, dangerous files/scripts, insecure default files, and common misconfigurations. It is one of the most widely taught tools for the vulnerability assessment phase of a web security engagement, following the reconnaissance phase (WHOIS, DNS, OSINT) already covered in earlier weeks.

### 12.1. Uses of Nikto

- Outdated web server and software versions with known vulnerabilities.
- Dangerous or default files/scripts left accessible on the server.
- Insecure HTTP headers and missing security configurations.
- Common directories and files that should not be publicly exposed.

### 13. Installing Nikto

**Step 1: Install Nikto**

sudo apt install nikto -y

Installs Nikto from the Kali repositories (already present by default on most Kali images).

```
└─$ sudo apt install nikto
[sudo] password for kosinko:
nikto is already the newest version (1:2.5.0+git20230114.90ff645-0kali1).
The following packages were automatically installed and are no longer required:
  libdnnl3  libxnnpack0
Use 'sudo apt autoremove' to remove them.

Summary:
  Upgrading: 0, Installing: 0, Removing: 0, Not Upgrading: 1356
```

**Step 2: Verify Installation**

nikto -Version

Displays the installed Nikto version and the current plugin/database version.

```
└─$ nikto -Version
Nikto 2.5.0 (LW 2.5)
```

**13. Nikto Command Syntax**

Basic syntax:

nikto -h <target>

-h (or -host) specifies the target host, which can be an IP address, hostname, or full URL.

**14. Running a Basic Scan**

Only run Nikto against a target you own or are explicitly authorised to test, designated training site.

**Step 1: Identify the Target**

Confirm the IP address of your assigned training target using ip a or the VirtualBox network settings.

**Step 2: Run the Scan**

nikto -h 192.168.56.10 or URL

Replace the IP address with your actual target. Nikto will begin scanning and print results line by line as it finds them.

```
└─$ nikto -h https://kosinkoblogs.wordpress.com/
- Nikto v2.5.0
---------------------------------------------------------------------------
+ Multiple IPs found: 192.0.78.13, 192.0.78.12
+ Target IP:          192.0.78.13
+ Target Hostname:    kosinkoblogs.wordpress.com
+ Target Port:        443
---------------------------------------------------------------------------
+ SSL Info:        Subject:  /CN=wordpress.com
                   Ciphers:  TLS_AES_256_GCM_SHA384
                   Issuer:   /C=US/O=Let's Encrypt/CN=E5
+ Start Time:         2025-06-13 05:29:23 (GMT1)
---------------------------------------------------------------------------
```

**Step 3: Wait for Completion**

Allow the scan to finish naturally — depending on the target, this can take several minutes. A summary and end time are printed once complete.

```
+ /remote-login.php: Cookie wp-settings-time-0 created without the secure flag. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Cookies
+ /remote-login.php: Cookie wp-settings-time-0 created without the httponly flag. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Cookies
+ /remote-login.php: Cookie wp_user created without the secure flag. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Cookies
+ /remote-login.php: Cookie wp_user created without the httponly flag. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Cookies
+ /remote-login.php: Cookie wp_pass created without the secure flag. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Cookies
+ /remote-login.php: Cookie wp_pass created without the httponly flag. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Cookies
+ /remote-login.php: Cookie wp-postpass_653166773dc88127bd3afe0b6dfe5ea7 created without the secure flag. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Cookies
+ /remote-login.php: Cookie wp-postpass_653166773dc88127bd3afe0b6dfe5ea7 created without the httponly flag. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Cooki
es
+ /wp-login.php: Uncommon header 'a8c-edge-cache' found, with contents: cache.
+ /robots.txt: contains 11 entries which should be manually viewed. See: https://developer.mozilla.org/en-US/docs/Glossary/Robots.txt
+ Hostname 'kosinkoblogs.wordpress.com' does not match certificate's names: wordpress.com. See: https://cwe.mitre.org/data/definitions/297.html
+ /: The Content-Encoding header is set to "deflate" which may mean that the server is vulnerable to the BREACH attack. See: http://breachattack.com/
+ ERROR: Error limit (20) reached for host, giving up. Last error: error reading HTTP response
+ Scan terminated: 20 error(s) and 30 item(s) reported on remote host
+ End Time:           2025-06-13 05:36:43 (GMT1) (440 seconds)
---------------------------------------------------------------------------
+ 1 host(s) tested
```

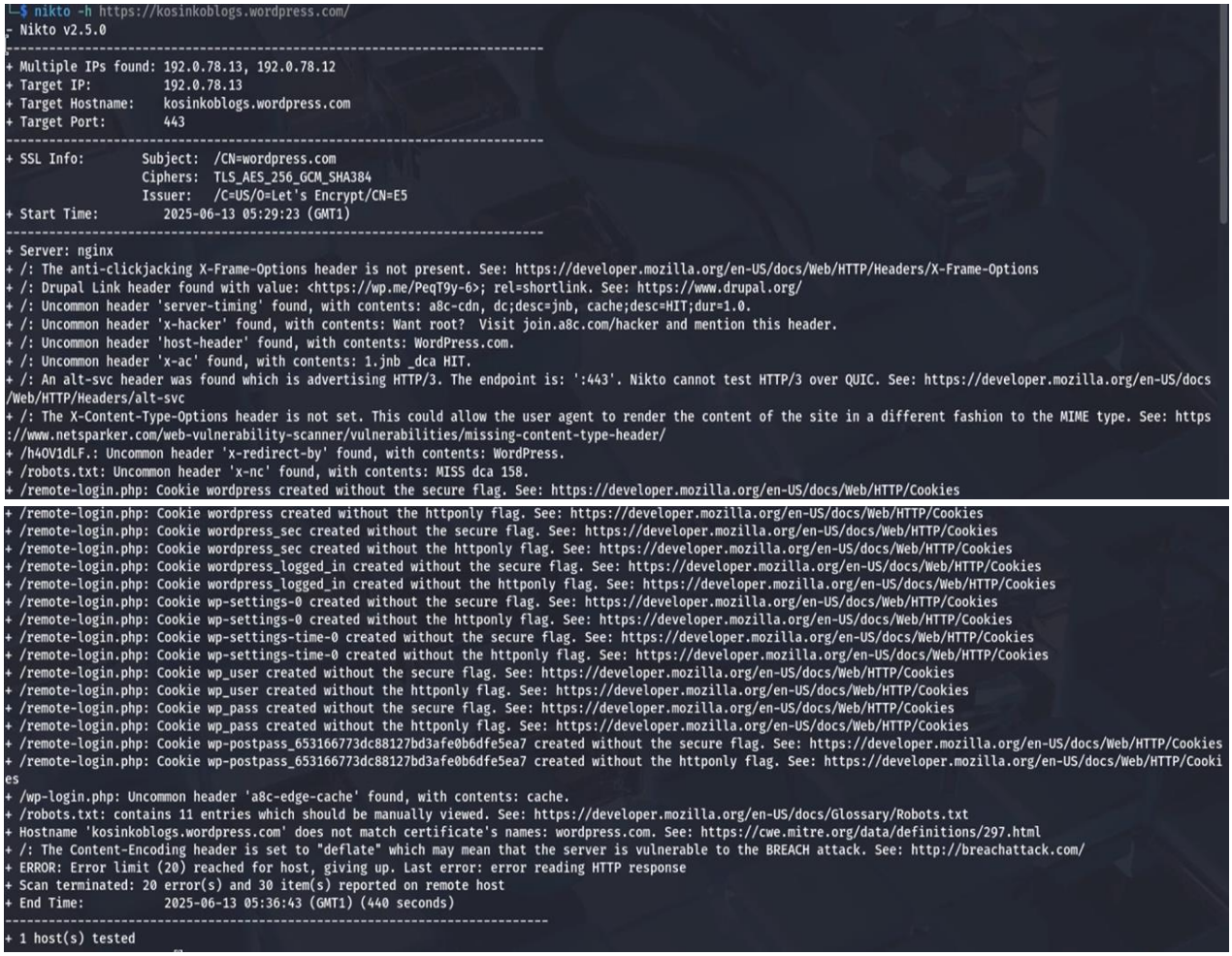
**15. Common Scan Options**

1. -h <target> — specifies the target host (required).
2. -p <port> — specifies a custom port (default is 80; use 443 for HTTPS).
3. -ssl — forces an SSL/HTTPS connection.
4. -o <file> — saves output to a file (e.g. -o report.txt).
5. -Format <type> — sets the output file format (txt, html, csv, xml).
6. -Tuning <options> — restricts the scan to specific vulnerability categories.

**16. Interpreting Nikto Output**

Each finding is printed as a separate line, typically starting with a plus sign (+), describing one specific issue or observation.

1. Server header disclosure — reveals the web server software and version in use.
2. Outdated software warnings — flags versions with publicly known vulnerabilities (often with a reference ID).
3. Interesting files/directories — default or backup files that should typically not be publicly accessible.
4. Missing security headers — such as X-Frame-Options or X-Content-Type-Options.



```
└─$ nikto -h https://kosinkoblogs.wordpress.com/
- Nikto v2.5.0
---------------------------------------------------------------------------
+ Multiple IPs found: 192.0.78.13, 192.0.78.12
+ Target IP:          192.0.78.13
+ Target Hostname:    kosinkoblogs.wordpress.com
+ Target Port:        443
---------------------------------------------------------------------------
+ SSL Info:        Subject:  /CN=wordpress.com
                   Ciphers:  TLS_AES_256_GCM_SHA384
                   Issuer:   /C=US/O=Let's Encrypt/CN=E5
+ Start Time:         2025-06-13 05:29:23 (GMT1)
---------------------------------------------------------------------------
+ Server: nginx
+ /: The anti-clickjacking X-Frame-Options header is not present. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/X-Frame-Options
+ /: Drupal Link header found with value: <https://wp.me/PeqT9y-6>; rel=shortlink. See: https://www.drupal.org/
+ /: Uncommon header 'server-timing' found, with contents: a8c-cdn, dc;desc=jnb, cache;desc=HIT;dur=1.0.
+ /: Uncommon header 'x-hacker' found, with contents: Want root?  Visit join.a8c.com/hacker and mention this header.
+ /: Uncommon header 'host-header' found, with contents: WordPress.com.
+ /: Uncommon header 'x-ac' found, with contents: 1.jnb _dca HIT.
+ /: An alt-svc header was found which is advertising HTTP/3. The endpoint is: ':443'. Nikto cannot test HTTP/3 over QUIC. See: https://developer.mozilla.org/en-US/docs
/Web/HTTP/Headers/alt-svc
+ /: The X-Content-Type-Options header is not set. This could allow the user agent to render the content of the site in a different fashion to the MIME type. See: https
://www.netsparker.com/web-vulnerability-scanner/vulnerabilities/missing-content-type-header/
+ /h4OV1dLF.: Uncommon header 'x-redirect-by' found, with contents: WordPress.
+ /robots.txt: Uncommon header 'x-nc' found, with contents: MISS dca 158.
+ /remote-login.php: Cookie wordpress created without the secure flag. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Cookies
+ /remote-login.php: Cookie wordpress created without the httponly flag. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Cookies
+ /remote-login.php: Cookie wordpress_sec created without the secure flag. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Cookies
+ /remote-login.php: Cookie wordpress_sec created without the httponly flag. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Cookies
+ /remote-login.php: Cookie wordpress_logged_in created without the secure flag. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Cookies
+ /remote-login.php: Cookie wordpress_logged_in created without the httponly flag. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Cookies
+ /remote-login.php: Cookie wp-settings-0 created without the secure flag. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Cookies
+ /remote-login.php: Cookie wp-settings-0 created without the httponly flag. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Cookies
+ /remote-login.php: Cookie wp-settings-time-0 created without the secure flag. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Cookies
+ /remote-login.php: Cookie wp-settings-time-0 created without the httponly flag. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Cookies
+ /remote-login.php: Cookie wp_user created without the secure flag. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Cookies
+ /remote-login.php: Cookie wp_user created without the httponly flag. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Cookies
+ /remote-login.php: Cookie wp_pass created without the secure flag. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Cookies
+ /remote-login.php: Cookie wp_pass created without the httponly flag. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Cookies
+ /remote-login.php: Cookie wp-postpass_653166773dc88127bd3afe0b6dfe5ea7 created without the secure flag. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Cookies
+ /remote-login.php: Cookie wp-postpass_653166773dc88127bd3afe0b6dfe5ea7 created without the httponly flag. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Cooki
es
+ /wp-login.php: Uncommon header 'a8c-edge-cache' found, with contents: cache.
+ /robots.txt: contains 11 entries which should be manually viewed. See: https://developer.mozilla.org/en-US/docs/Glossary/Robots.txt
+ Hostname 'kosinkoblogs.wordpress.com' does not match certificate's names: wordpress.com. See: https://cwe.mitre.org/data/definitions/297.html
+ /: The Content-Encoding header is set to "deflate" which may mean that the server is vulnerable to the BREACH attack. See: http://breachattack.com/
+ ERROR: Error limit (20) reached for host, giving up. Last error: error reading HTTP response
+ Scan terminated: 20 error(s) and 30 item(s) reported on remote host
+ End Time:           2025-06-13 05:36:43 (GMT1) (440 seconds)
---------------------------------------------------------------------------
+ 1 host(s) tested
```